Vulnerability Assessment Report

PASSIVE SECURITY ASSESSMENT OF
TESTPHP.VULNWEB.COM

Prepared by:
Bansari Panchal
Cyber Security Intern
Future Interns – 2026

SUMMARY

- A passive vulnerability assessment was conducted on the publicly accessible website testphp.vulnweb.com to identify security misconfigurations and potential exposure risks.
- The assessment was strictly limited to passive analysis techniques and did not involve exploitation, brute-force attempts, credential testing, or intrusive attacks. The objective was to evaluate publicly observable weaknesses and configuration issues that may increase the application's exposure to common web-based threats.
- Several configuration-related weaknesses were identified, primarily involving missing security headers and information disclosure through HTTP responses. While no critical vulnerabilities were detected, remediation of the identified issues will significantly improve the application's overall security posture.

TARGET INFORMATION

Target Name: testphp.vulnweb.com
Target Type: Public Web Application
Testing Environment: Kali Linux (VMware Workstation)
Assessment Type: Passive Web Application Security Assessment

- The target website was assessed using non-intrusive security testing techniques to evaluate publicly accessible components and server configurations.

SCOPE & METHODOLOGY

Scope

- Public-facing website only
- Passive scanning techniques only
- No authentication bypass attempts
- No exploitation performed
- No modification of target system
- No brute-force or denial-of-service testing

Tools Used

- Nmap (Port and service identification)
- OWASP ZAP (Passive vulnerability scanning)
- Browser Developer Tools (HTTP header inspection)

Methodology

1. Reconnaissance phase using Nmap to identify exposed ports and services.
2. Passive vulnerability assessment using OWASP ZAP.
3. Manual verification of HTTP response headers and server information.
4. Risk classification based on observed misconfigurations.

TECHNICAL OVERVIEW

Port & Service Analysis (Nmap Results)

An Nmap scan was conducted to identify open ports and exposed services on the target system.

Findings:

- Port 80 (HTTP) open
- Web server identified as nginx 1.19.0
- Server response headers revealed version information

The exposure of service and version information may assist attackers in identifying known vulnerabilities associated with specific software versions.

DETAILED VULNERABILITY ANALYSIS

Finding 1 – Content Security Policy (CSP) Header Not Set

Risk Level: Medium
Description:
The application does not implement a Content Security Policy (CSP) header in HTTP responses.
Business Impact:
The absence of CSP increases the risk of Cross-Site Scripting (XSS) attacks, which may allow attackers to inject malicious scripts into web pages and compromise user data.
Recommendation:
Implement a properly configured Content-Security-Policy header restricting trusted sources.

Finding 2 – Missing Anti-Clickjacking Header

Risk Level: Medium
Description:
The application does not define the X-Frame-Options header or equivalent frame-ancestors directive.
Business Impact:
The website may be embedded into malicious iframes, increasing the risk of clickjacking attacks.
Recommendation:
Add X-Frame-Options header set to DENY or SAMEORIGIN.

Finding 3 – Absence of Anti-CSRF Tokens

Risk Level: Low
Description:
HTML forms do not appear to implement anti-CSRF tokens.
Business Impact:
This may allow attackers to perform unauthorized actions on behalf of authenticated users through Cross-Site Request Forgery attacks.
Recommendation:
Implement CSRF token validation for all state-changing requests.

Finding 4 – Server Information Disclosure via X-Powered-By Header

Risk Level: Low
Description:
The HTTP response includes the X-Powered-By header revealing backend technology information.
Business Impact:
Disclosure of backend technologies may assist attackers in identifying specific vulnerabilities associated with the revealed software stack.
Recommendation:
Remove or suppress the X-Powered-By header in server responses.

Finding 5 – Server Version Disclosure via Server Header

Risk Level: Low
Description:
The Server header reveals the web server version (nginx 1.19.0).
Business Impact:
Exposing server version information may enable attackers to identify known exploits targeting that specific version.
Recommendation:
Configure the server to hide version details in HTTP response headers.

Finding 6 – X-Content-Type-Options Header Missing

Risk Level: Low
Description:
The X-Content-Type-Options header is not set to prevent MIME-type sniffing.
Business Impact:
This may allow browsers to interpret files as a different content type, potentially leading to security issues.
Recommendation:
Add the header:
X-Content-Type-Options: nosniff

Finding 7 – Charset Mismatch

Risk Level: Informational
Description:
A mismatch was identified between the charset declared in the HTTP header and the charset defined in the HTML content.
Business Impact:
Although not directly exploitable, inconsistent charset declarations may cause parsing inconsistencies in certain scenarios.
Recommendation:
Ensure consistent charset configuration between HTTP headers and HTML content.

Conclusion

- The passive security assessment identified multiple configuration weaknesses related to missing security headers and information disclosure. While no critical vulnerabilities were discovered, the presence of medium and low-level issues increases potential exposure to common web-based attacks.

- Remediating the identified findings will significantly enhance the overall security posture of the application and reduce potential attack surface.